

Соответствие приказу Роскомнадзора № 140 от 19.06.2025

07_Соответствие_приказу_РКН_140.md

Аудит текущей реализации и план доведения до полного соответствия

Дата: 16.08.2026. Приказ действует с 01.09.2025 (зарегистрирован в Минюсте 31.07.2025, № 83110), заменил приказ РКН № 996 от 05.09.2013.

0. Главный вывод, снимающий прежнюю оценку

В `ЮРИДИЧЕСКИЙ_АНАЛИЗ.md` (п. А.3) утверждалось, что результат работы сервиса не может называться обезличиванием, потому что операция обратима. Это утверждение было слишком категоричным и снимается.

Приложение № 2 к приказу № 140, пункт 3, прямо предусматривает обратный механизм:

«В случае применения метода введения идентификаторов должно предусматриваться создание ключа, позволяющего сопоставить идентификаторы и персональные данные, в отношении которых были произведены действия по обезличиванию персональных данных, который хранится оператором отдельно от массива персональных данных, подлежащих обезличиванию, ... и не передаваться третьим лицам.»

Иначе говоря, создание ключа — не порок метода, а его обязательный элемент. Определение п. 9 ст. 3 152-ФЗ требует невозможности идентификации «без использования дополнительной информации» — а не отсутствия такой информации в природе.

Правильная формулировка проблемы: обезличивание не состоялось не из-за обратимости, а из-за того, что ключ доставляется получателю в том же объекте, что и результат. Как только они разнесены — обезличивание состоялось в полном юридическом смысле.

Это существенно улучшает позицию: путь к легальному использованию термина «обезличивание» короче, чем предполагалось, и не требует отказа от обратимости.

0-бис. Кому адресованы требования приказа — и являетесь ли вы этим лицом

Пункт 1 требований начинается словами: «При обезличивании персональных данных оператор <2> должен обеспечить», где сноска <2> отсылает к пункту 2 статьи 3 152-ФЗ. **Адресат требований — оператор.** Лицо, осуществляющее обработку по поручению, оператором не является.

Оператор определяется не размещением оборудования, а целями обработки. П. 2 ст. 3 152-ФЗ: «оператор — ... юридическое или физическое лицо, самостоятельно или совместно с другими лицами организующие и (или) осуществляющие обработку персональных данных, а также определяющие цели обработки персональных данных, состав персональных данных, подлежащих обработке, действия (операции), совершаемые с персональными данными». Слов про серверы, ЦОД и место размещения в определении нет.

Отсюда — распределение ролей по конфигурациям:

Конфигурация	Оператор	Ваша роль	Адресат приказа № 140
Сервис работает самостоятельно, пользователи загружают документы	Вы — определяете цели, состав, операции	Оператор	Вы, напрямую
Работа по поручению заказчика (модель для ИНК)	Заказчик (ИНК)	Лицо, осуществляющее обработку по поручению (ч. 3 ст. 6)	Заказчик. Требования приходят к вам договорным путём, а не напрямую из приказа
Собственные данные (клиенты, контрагенты, журналы)	Вы, всегда	Оператор	Вы

ООО «ИНТЕРФОНИКА» оператором ваших данных не становится ни в одной конфигурации — она не определяет цели обработки. Она лицо, осуществляющее обработку по поручению (хостинг и инференс-шлюз), и одновременно оператор в отношении собственных данных: ваших платежей, контактов, реквизитов.

Практические следствия:

1. Размещение на чужой инфраструктуре **не снимает** обязанностей по ст. 18.1 и 19 152-ФЗ. Наоборот — порождает необходимость договора поручения с провайдером.
2. По ч. 5 ст. 6 ответственность перед субъектом несёт оператор, а лицо, осуществляющее обработку, отвечает **перед оператором**. В модели поручения вы — регрессное звено.
3. Готовить соответствие приказу № 140 нужно в любом случае: до сделки вы оператор напрямую; после — заказчик возложит те же требования договором, поскольку операцию физически выполняете вы.
4. **Приложение № 2, п. 3 в модели поручения складывается в вашу пользу.** Требование «ключ хранится **оператором** отдельно... и не передаваться третьим лицам» при операторе-заказчике означает, что ключ должен храниться у заказчика. Возврат mapping оператору — не нарушение, а исполнение требования: третьим лицам ключ при этом не передаётся.

1. Применяемый метод

Реализация в `mapping.py` (`assign_placeholders`, `placeholder_for`) соответствует **методу введения идентификаторов** — пункт 2 приложения № 2:

«...выделения из состава персональных данных, подлежащих обезличиванию, ... персональных данных, которые без использования дополнительной информации позволяют определить субъекта персональных данных, и их замены на идентификаторы **в виде кода, номера или иного обозначения**, имеющего постоянное или переменное значение, **присваиваемые на основании заданных оператором алгоритмов.**»

Плейсхолдеры вида `[PASSPORT_1]`, `[PERSON_2]` — идентификаторы в виде обозначения; нумерация по порядку первого появления в тексте — заданный оператором алгоритм. Метод входит в разрешённый перечень (п. 1 приложения № 2 допускает методы из пунктов 2, 4, 10, 11 и 12).

Метод менять не нужно. Его нужно зафиксировать в локальном акте — сейчас нигде не задокументировано, что применяется именно он.

2. Матрица соответствия

Легенда: ☒ выполнено · ☐ частично · ✗ не выполнено · ⚠ зависит от роли

Раздел 1 требований

Пункт	Требование	Статус	Фактическое положение
1.1	Использование методов из приложения № 2	☐	Метод введения идентификаторов фактически реализован (<code>mapping.py</code>), но не зафиксирован документально
1.2	Определение до начала состава ПДн, подлежащих обезличиванию, и субъектов	✗	Состав определяется детекторами на лету. При этом закрытый перечень меток существует: EMAIL, URL, IP_ADDRESS, PHONE, CREDIT_CARD, INN, SNILS, OMS, PASSPORT, DRIVER_LICENSE, MILITARY_ID, BIRTH_CERTIFICATE, PERSON и др. Этот перечень и есть «состав» — его достаточно оформить актом
1.3	Оценка достаточности выбранного метода	☐	Инструмент готов (<code>eval_benchmark.py</code>), протокол оценки не оформлен
1.4	Невозможность идентификации без дополнительной информации	☐	Алгоритмически достигается, но обнуляется доставкой ключа вместе с результатом
1.5	ИС обеспечивает безопасность и конфиденциальность исходного массива и результата	✗	Нет аутентификации входящих запросов; Access-Control-Allow-Origin: *; <code>job_id</code> не привязан к субъекту (IDOR)
1.6	Исключение совместного хранения исходного массива и результата	✗	<code>_JOBS[job_id]["result"]</code> содержит <code>anonymized_text</code> , <code>mapping</code> , <code>spans</code> (с исходными подстроками и смещениями) и <code>document_base64</code> одновременно; TTL 600 с, очистка ленивая
1.7	Учёт действий по обезличиванию в определённой оператором форме	✗	<code>usage_log.py</code> ведёт учёт потребления (токены, стоимость, длительность), а не учёт операций обезличивания. Формы, подтверждающей осуществлённые действия, нет

Приложение № 2, пункт 3 (ключ)

Требование	Статус	Фактическое положение
Создание ключа	☒	<code>mapping.py</code> формирует <code>placeholder</code> → <code>original</code>

Требование	Статус	Фактическое положение
Хранится оператором отдельно от массива ПДн	✗	Хранится в одной структуре с результатом и передаётся в одном ответе
Не передаётся третьим лицам	⚠	Зависит от роли. Если оператор — вы, передача ключа клиенту недопустима. Если вы обработчик по поручению , а оператор — заказчик, ключ возвращается оператору и третьим лицам не передаётся. Модель поручения закрывает этот пункт сама

Раздел 2 требований

Пункт	Требование	Статус	Комментарий
2.1	Локальные акты о порядке обработки, обезличивания, оценки достаточности метода	✗	Отсутствуют
2.2	Исключение доступа третьих лиц к информации о методе, используемых ИС и процедуре	✗	README.md, ПРЕЗЕНТАЦИЯ.md, МАТЧАСТЬ.md публично описывают алгоритм, метки и архитектуру. Прямой конфликт с маркетингом , требует решения
2.3–2.5	Локальные акты для методов 4, 10, 11	n/a	Не применяются, если ограничиться методом введения идентификаторов
2.6	Хранение локальных актов отдельно от результата, без доступа третьих лиц	n/a → ✗	Станет применимо после появления актов
2.7	Требования при использовании метода 12 (обобщение)	n/a	Не применяется

Итог: полное соответствие — примерно 1,5 пункта из 7 по разделу 1.

3. Что реализовать в коде

Порядок — по убыванию отдачи на единицу трудозатрат.

№	Задача	Закрывает	Трудоёмкость	Ломает совместимость
3.1	Убрать text из сериализуемых спанов , ввести флаг <code>include_span_text</code> (по умолчанию <code>false</code>)	1.4, 1.6	0,5 дня	Частично: <code>remote_client.py:99</code> читает <code>s.get("text", "")</code> — клиент должен выставлять флаг. Фронтенд поле не использует (проверено)

№	Задача	Закрывает	Трудоёмкость	Ломает совместимость
3.2	Развести выдачу результата и ключа: GET /jobs/{id}/document и GET /jobs/{id}/key; ключ выдаётся один раз и немедленно стирается из _JOBS	1.6, прил. 2 п. 3	1–2 дня	Да — новый контракт. Рекомендуется добавить рядом со старым и объявить старый устаревшим
3.3	Уничтожение исходного массива сразу после формирования результата: явное освобождение raw/text, отключение core dumps (RLIMIT_CORE=0), mlock для страниц с ключом	1.6 (разделение во времени)	1 день	Нет
3.4	Детерминированный TTL: фоновый сборщик вместо ленивой очистки; удаление задания сразу после первой успешной выдачи	1.5, 1.6	0,5 дня	Нет
3.5	Аутентификация входящих запросов , Access-Control-Allow-Origin из белого списка, привязка job_id к субъекту, криптостойкий идентификатор	1.5	2 дня	Да, для клиентов — нужен токен
3.6	Журнал операций обезличивания — отдельный от usage.jsonl: request_id, дата и время начала и окончания, субъект доступа, применённый метод, перечень задействованных меток, количество замен по меткам, факт выдачи ключа с отметкой времени, факт уничтожения исходного массива и ключа. Без содержимого ПДн	1.7	1–2 дня	Нет
3.7	Режим без формирования ключа (irreversible=true): маппинг не создаётся и не возвращается	1.4 в жёстком варианте	0,5 дня	Нет, новый флаг
3.8	Опционально: шифрование ключа при выдаче ключом клиента	усиление прил. 2 п. 3	2–3 дня	Нет

Совокупно — **7–11 рабочих дней**. Пункты 3.1, 3.3, 3.4, 3.6, 3.7 совместимость не ломают и могут быть сделаны сразу.

4. Что оформить документально

№	Документ	Закрывает	Содержание
4.1	Локальный акт «Порядок обезличивания»	2.1, 1.1, 1.2, 1.6	Применяемый метод со ссылкой на п. 2 приложения № 2 к приказу № 140; алгоритм присвоения идентификаторов; состав ПДн, подлежащих обезличиванию — закрытый перечень меток;

№	Документ	Закрывает	Содержание
	персональных данных»		категории субъектов; порядок создания, хранения, выдачи и уничтожения ключа; избранный способ исключения совместного хранения с обоснованием ; форма учёта
4.2	Протокол оценки достаточности метода	1.3	Методика измерения, состав и объём эталонного набора, полученные значения полноты и точности по каждой метке, дата, версия моделей, вывод о достаточности для заявленных целей. Формируется на базе eval_benchmark.py
4.3	Форма журнала учёта действий по обезличиванию	1.7	Утверждается как приложение к акту 4.1; заполняется автоматически по задаче 3.6
4.4	Акт об определении состава ПДн и категорий субъектов	1.2	Фиксируется до начала обработки. Поимённо субъектов определить нельзя — указываются категории, и это допустимо
4.5	Порядок хранения локальных актов	2.6	Отдельно от результатов обезличивания, с ограничением доступа
4.6	Решение по публичной документации	2.2	См. раздел 5

5. Конфликт пункта 2.2 с открытой документацией

Пункт 2.2 требует исключить доступ третьих лиц к информации об используемом методе, об используемых информационных системах и программах, «а равно иной информации о процедуре проведения обезличивания».

Сейчас в открытом доступе: README.md (перечень меток, состав модулей), ПРЕЗЕНТАЦИЯ.md (описание трёхслойной архитектуры), МАТЧАСТЬ.md (детальное описание меток и логики).

Три возможных решения:

1. **Закрывать детальное описание.** МАТЧАСТЬ.md и подробности алгоритма перевести в закрытую часть, предоставляемую заказчику под NDA. В публичных материалах оставить функциональное описание без процедурных деталей. *Рекомендуется при выборе режима «обезличивание».*
2. **Не применять режим обезличивания.** Позиционировать продукт как маскирование — тогда приказ № 140 не применяется, и требование 2.2 тоже. Документация остаётся открытой.
3. **Два режима.** Публичная документация описывает режим маскирования; режим обезличивания документируется закрыто и поставляется отдельно. *Наиболее гибко, но требует дисциплины при поддержке двух комплектов документации.*

6. Рекомендуемая последовательность

Этап 1 — без изменения контракта API (3–4 дня). Задачи 3.1, 3.3, 3.4, 3.6, 3.7. К концу этапа закрыты п. 1.7 и частично 1.6.

Этап 2 — документы (5–7 дней, параллельно). Документы 4.1, 4.2, 4.3, 4.4. К концу этапа закрыты п. 1.1, 1.2, 1.3, 2.1.

Этап 3 — изменение контракта (3–4 дня). Задачи 3.2 и 3.5. Закрывают п. 1.5, 1.6 и приложение № 2 п. 3 полностью.

Этап 4 — решение по документации (1 день). Раздел 5, закрывает п. 2.2.

После всех четырёх этапов соответствие приказу № 140 полное, и **термин «обезличивание» становится юридически корректным** — при условии, что ключ хранится отдельно и не передаётся третьим лицам (что обеспечивается либо режимом 3.7, либо моделью поручения обработки).

7. Оговорка

Приказ № 140 действует менее года, правоприменительная практика по нему не сформирована. Толкование пунктов 1.2 (определение состава «до начала» при потоковой обработке произвольных документов) и 2.2 (граница «информации о процедуре») **спорно**. Приведённые выше решения — консервативные. До вендорского аудита заказчика уровня ИНК рекомендуется согласовать позицию с практикующим юристом по персональным данным.